

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
I	Common provisions	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.1	Scope and definitions	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.1.1	Scope of the Act	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.1.2	Definitions	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.2	Legal basis for processing personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.3	Processing of personal data by public bodies	Public bodies shall be permitted to process personal data if such processing is necessary to perform the task for which the controller is responsible or to exercise official authority which has been vested in the controller.	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4	Video surveillance of publicly accessible spaces	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(1)	Video surveillance of publicly accessible spaces	Monitoring publicly accessible areas with optical-electronic devices (video surveillance) shall be permitted only as far as it is necessary	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(1)1	Video surveillance of publicly accessible spaces	for public bodies to perform their tasks,	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(1)2	Video surveillance of publicly accessible spaces	to exercise the right to determine who shall be allowed or denied access or	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(1)3	Video surveillance of publicly accessible spaces	to safeguard legitimate interests for specifically defined purposes and if there is nothing to indicate legitimate overriding interests of the data subjects. For video surveillance of	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(1)3.1	Video surveillance of publicly accessible spaces	large publicly accessible facilities, such as sport facilities, places of gathering and entertainment, shopping centres and car parks, or	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(1)3.2	Video surveillance of publicly accessible spaces	vehicles and large publicly accessible facilities of public rail, ship or bus transport, protecting the lives, health and freedom of persons present shall be regarded as a very important interest.	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(2)	Video surveillance of publicly accessible spaces	Appropriate measures shall be taken to make the surveillance and the controller's name and contact details identifiable as early as possible.	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(3)	Video surveillance of publicly accessible spaces	Storing or using data collected pursuant to subsection 1 shall be permitted if necessary to achieve the intended purpose and if there is nothing to indicate legitimate overriding interests of the data subjects. Subsection 1,	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(4)	Video surveillance of publicly accessible spaces	If data collected from video surveillance are attributed to a particular person, that person shall be informed of the processing in accordance with Articles 13 and 14 of Regulation (EU) 2016/679. Section 32 shall apply	Functional	No Relationship	N/A	N/A	N/A	0	
I.2.4(5)	Video surveillance of publicly accessible spaces	The data shall be deleted without delay, if they are no longer needed for the intended purpose or if the data subject's legitimate interests stand in the way of any further storage.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3	Data protection officers of public bodies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.5	Designation	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.5(1)	Designation	Public bodies shall designate a data protection officer. This shall also apply to public bodies as defined in Section 2 (5) which take part in competition.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.5(2)	Designation	A single data protection officer may be designated for several public bodies, taking account of their organizational structure and size.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.5(3)	Designation	The data protection officer shall be designated on the basis of professional qualities and, in particular, expert knowledge of data protection law and	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.5(4)	Designation	The data protection officer may be a staff member of the public body, or fulfil the tasks on the basis of a service contract.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.5(5)	Designation	The public body shall publish the contact details of the data protection officer and communicate them to the Federal Commissioner for Data Protection and Freedom of Information.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6	Position	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6(1)	Position	The public body shall ensure that the data protection officer is involved, properly and in a timely manner, in all issues which relate to the protection of personal data.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6(2)	Position	The public body shall support the data protection officer in performing the tasks referred to in Section 7 by providing resources necessary to carry out	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6(3)	Position	The public body shall ensure that the data protection officer does not receive any instructions regarding the exercise of those tasks. The data	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6(4)	Position	The dismissal of the data protection officer shall be permitted only by applying Section 626 of the Civil Code accordingly. The data protection officer's employment shall not be terminated unless there are facts which	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6(5)	Position	Data subjects may contact the data protection officer with regard to all issues related to processing of their personal data and to the exercise of their rights under Regulation (EU) 2016/679, this Act and other data	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.6(6)	Position	Where in the course of their activities data protection officers become aware of data for which the head of a public body or a person employed by	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7	Tasks	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(1)	Tasks	In addition to the tasks listed in Regulation (EU) 2016/679, the data protection officer shall have at least the following tasks: In the case of a data protection officer ordered by a court, these tasks shall not refer to the action of the court acting in its judicial capacity.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(1)1	Tasks	to inform and advise the public body and the employees who carry out processing of their obligations pursuant to this Act and other data protection legislation, including legislation enacted to implement Directive (EU) 2016/680;	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(1)2	Tasks	to monitor compliance with this Act and other data protection legislation, including legislation enacted to implement Directive (EU) 2016/680, and with the policies of the public body in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits;	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(1)3	Tasks	to provide advice as regards the data protection impact assessment and monitor its implementation pursuant to Section 67 of this Act;	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
I.3.7(1)4	Tasks	to cooperate with the supervisory authority;	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(1)5	Tasks	to act as the contact point for the supervisory authority on issues relating to processing, including the prior consultation referred to in Section 69 of	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(2)	Tasks	The data protection officer may perform other tasks and duties. The controller or processor shall ensure that any such tasks and duties do not result in a conflict of interests.	Functional	No Relationship	N/A	N/A	N/A	0	
I.3.7(3)	Tasks	The data protection officer shall in the performance of his or her tasks give due regard to the risk associated with processing operations, taking into account the nature, scope, context and purposes of processing.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4	Federal Commissioner for Data Protection and Freedom of Information	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.8	Establishment	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.9	Competence	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.10	Independence	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.11	Appointment and term of office	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.12	Official relationship	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.13	Rights and obligations	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14	Tasks	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)	Tasks	In addition to the tasks listed in Regulation (EU) 2016/679, the Federal Commissioner shall have the following tasks: Within the scope of Directive (EU) 2016/680, the Federal Commissioner shall also perform the task pursuant to Section 60.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)1	Tasks	to monitor and enforce the application of this Act and other data protection legislation, including legislation adopted to implement Directive (EU) 2016/680;	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)2	Tasks	to promote public awareness and understanding of the risks, rules, safeguards and rights in relation to the processing of personal data, paying special attention to measures specifically for children;	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)3	Tasks	to advise the German Bundestag, the Bundesrat, the Federal Government, and other institutions and bodies on legislative and administrative measures relating to the protection of natural persons' rights and	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)4	Tasks	to promote the awareness of controllers and processors of their obligations under this Act and other data protection legislation, including legislation adopted to implement Directive (EU) 2016/680;	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)5	Tasks	upon request, to provide information to any data subject concerning the exercise of their rights under this Act and other data protection legislation, including legislation adopted to implement Directive (EU) 2016/680, and if appropriate, to cooperate with the supervisory authorities in other Member	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)6	Tasks	to handle complaints lodged by a data subject, or by a body, organization or association in accordance with Article 55 of Directive (EU) 2016/680, and investigate, to the extent appropriate, the subject matter of the	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)7	Tasks	to cooperate with, including by sharing information, and provide mutual assistance to other supervisory authorities, to ensure the consistency of	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)8	Tasks	to conduct investigations on the application of this Act and other data protection legislation, including legislation adopted to implement Directive	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)9	Tasks	to monitor relevant developments, insofar as they have an impact on the protection of personal data, in particular the development of information	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)10	Tasks	to provide advice on the processing operations referred to in Section 69; and	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(1)11	Tasks	to contribute to the activities of the European Data Protection Board.	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(2)	Tasks	To carry out the task listed in subsection 1, first sentence, no. 3, the Federal Commissioner may, on request or at its own initiative, make	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(3)	Tasks	The Federal Commissioner shall facilitate the submission of complaints referred to in subsection 1, first sentence, no. 6 by measures such as	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.14(4)	Tasks	The performance of the duties of the Federal Commissioner shall be free of charge for the data subject. Where requests are manifestly unfounded or excessive, in particular because of their repetitive character, the Federal Commissioner may charge a reasonable fee based on administrative	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.15	Activity reports	The Federal Commissioner shall produce an annual activity report which may contain a list of the types of violations reported and the types of measures taken, including penalties and measures taken in accordance	Functional	No Relationship	N/A	N/A	N/A	0	
I.4.16	Powers	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.5	Representation on the European Data Protection Board, single contact point.	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.5.17	Representation on the European Data Protection Board, single	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.5.18	Procedures for cooperation among the federal and Lnder supervisory authorities	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
I.5.19	Responsibilities	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.6	Legal remedies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
I.6.20	Judicial remedy	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
I.6.21	Application of the supervisory authority for a court decision if it believes that an	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2	Implementing provisions for processing for	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1	Legal basis for processing personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1	Processing of special categories of personal data and processing for other purposes	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.22	Processing of special categories of personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.22(1)	Processing of special categories of personal data	By derogation from Article 9 (1) of Regulation (EU) 2016/679, the processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 shall be permitted and as far as the interests of the controller in data processing in the cases of no. 1 (d) and no. 2 outweigh the interests of the data subject.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)1	Processing of special categories of personal data	by public and private bodies if	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)1(a)	Processing of special categories of personal data	processing is necessary to exercise the rights derived from the right of social security and social protection and to meet the related obligations; processing is necessary for the purposes of preventive medicine, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems and services or pursuant to the data subject's contract with a health professional and if these data are processed by health professionals or other persons subject to the obligation of professional secrecy or under their supervision;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)1(b)	Processing of special categories of personal data	processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicinal products or medical devices; in addition to the measures	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)1(c)	Processing of special categories of personal data	processing is urgently necessary for reasons of substantial public interest;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)1(d)	Processing of special categories of personal data	processing is necessary to prevent a substantial threat to public security;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)2	Processing of special categories of personal data	processing is necessary to prevent substantial harm to the common good or to safeguard substantial concerns of the common good;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(1)2(a)	Processing of special categories of personal data	processing is necessary for urgent reasons of defence or to fulfil supra- or intergovernmental obligations of a public body of the Federation in the field of crisis management or conflict prevention or for humanitarian measures;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.22(1)2(b)	Processing of special categories of personal data	In the cases of subsection 1, appropriate and specific measures shall be taken to safeguard the interests of the data subject. Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, these measures may include in particular the following: technical organizational measures to ensure that processing complies with Regulation (EU) 2016/679;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(2)	Processing of special categories of personal data	measures to ensure that it is subsequently possible to verify and establish whether and by whom personal data were input, altered or removed;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(2)1	Processing of special categories of personal data	measures to increase awareness of staff involved in processing operations;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(2)2	Processing of special categories of personal data	designation of a data protection officer;	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
2.1.1.22(2)3	Processing of special categories of personal data	restrictions on access to personal data within the controller and by processors;	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.1.1.22(2)6	Processing of special categories of personal data	the pseudonymization of personal data;	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
2.1.1.22(2)7	Processing of special categories of personal data	the encryption of personal data;	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
2.1.1.22(2)8	Processing of special categories of personal data	measures to ensure the ability, confidentiality, integrity, availability and resilience of processing systems and services related to the processing of personal data, including the ability to rapidly restore availability and access in the event of a physical or technical incident;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(2)9	Processing of special categories of personal data	a process for regularly testing, assessing and evaluating the effectiveness of technical and organizational measures for ensuring the security of the processing;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.22(2)10	Processing of special categories of personal data	specific rules of procedure to ensure compliance with this Act and with Regulation (EU) 2016/679 in the event of transfer or processing for other purposes.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy	5	
2.1.1.23	Processing for other purposes by public bodies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)	Processing for other purposes by public bodies	Public bodies shall be permitted to process personal data for a purpose other than the one for which the data were collected where such processing is necessary for them to perform their duties and if	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)1	Processing for other purposes by public bodies	it is obviously in the interest of the data subject and there is no reason to assume that the data subject would refuse consent if he or she were aware of the other purpose;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)2	Processing for other purposes by public bodies	it is necessary to check information provided by the data subject because there is reason to believe that this information is incorrect;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)3	Processing for other purposes by public bodies	processing is necessary to prevent substantial harm to the common good or a threat to public security, defence or national security; to safeguard substantial concerns of the common good; or to ensure tax and customs revenues;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)4	Processing for other purposes by public bodies	processing is necessary to prosecute criminal or administrative offences, to carry out or enforce punishment or measures as referred to in Section 11 (1) no. 8 of the Criminal Code or educational or disciplinary measures as referred to in the Juvenile Court Act or to enforce fines;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)5	Processing for other purposes by public bodies	processing is necessary to prevent serious harm to the rights of another person; or	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(1)6	Processing for other purposes by public bodies	processing is necessary to exercise powers of supervision and monitoring, to conduct audits or organizational analyses of the controller; this shall also apply to processing for training and examination purposes by the controller, as long as it does not conflict with the legitimate interests of the data subject.	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.23(2)	Processing for other purposes by public bodies	The processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 for a purpose other than the one for which the data were collected shall be permitted if the conditions of subsection 1 are met and an exception pursuant to Article 9 (2) of	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.24	Processing for other purposes by private bodies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.24(1)	Processing for other purposes by private bodies	Private bodies shall be permitted to process personal data for a purpose other than the one for which the data were collected if unless the data subject has an overriding interest in not having the data processed	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	8	
2.1.1.24(1)1	Processing for other purposes by private bodies	processing is necessary to prevent threats to state or public security or to prosecute criminal offences; or	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	8	
2.1.1.24(1)2	Processing for other purposes by private bodies	processing is necessary for the establishment, exercise or defence of legal claims,	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	8	
2.1.1.24(2)	Processing for other purposes by private bodies	The processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 for a purpose other than the one for which the data were collected shall be permitted if the conditions of subsection 1 are met and an exception pursuant to Article 9 (2) of Regulation (EU) 2016/679 or pursuant to Section 22 applies.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.1.1.25	Transfer of data by public bodies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.25(1)	Transfer of data by public bodies	The transfer of personal data by public bodies to public bodies shall be permitted if it is necessary for the transferring body or the third party to whom the data are transferred to perform their duties and the conditions	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.1.1.25(2)	Transfer of data by public bodies	Public bodies shall be permitted to transfer personal data to private bodies if	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.25(1)1	Transfer of data by public bodies	transfer is necessary for the transferring body to perform its duties and the conditions are met which would permit processing pursuant to Section 23;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.25(1)2	Transfer of data by public bodies	the third party to whom the data are transferred credibly presents a legitimate interest in knowledge of the data to be transferred and the data subject does not have a legitimate interest in not having the data transferred; or	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.1.25(1)3	Transfer of data by public bodies	processing is necessary for the establishment, exercise or defence of legal claims;	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2	Special processing situations	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.26	Data processing for employment-related purposes	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.26(1)	Data processing for employment-related purposes	Personal data of employees may be processed for employment-related purposes where necessary for hiring decisions or, after hiring, for carrying out or terminating the employment contract or to exercise or satisfy rights and obligations of employees' representation laid down by law or by collective agreements or other agreements between the employer and staff council. Employees' personal data may be processed to detect crimes only	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	8	
2.1.2.26(2)	Data processing for employment-related purposes	If personal data of employees are processed on the basis of consent, then the employee's level of dependence in the employment relationship and the circumstances under which consent was given shall be taken into	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is	8	
2.1.2.26(2)	Data processing for employment-related purposes	If personal data of employees are processed on the basis of consent, then the employee's level of dependence in the employment relationship and the circumstances under which consent was given shall be taken into account in assessing whether such consent was freely given. Consent may be freely given in particular if it is associated with a legal or economic advantage for the employee, or if the employer and employee are pursuing the same interests. Consent shall be given in written or electronic form.	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	5	
2.1.2.26(3)	Data processing for employment-related purposes	By derogation from Article 9 (1) of Regulation (EU) 2016/679, the processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 for employment-related purposes shall be permitted if it is necessary to exercise rights or comply with legal obligations derived from labour law, social security and social protection law, and there is no reason to believe that the data subject has an overriding legitimate interest in not processing the data. Subsection 2 shall	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with: (1) Plain language explaining the potential data privacy risks of the authorization; (2) A means to decline the authorization; and	8	
2.1.2.26(3)	Data processing for employment-related purposes	By derogation from Article 9 (1) of Regulation (EU) 2016/679, the processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 for employment-related purposes shall be permitted if it is necessary to exercise rights or comply with legal obligations derived from labour law, social security and social protection law, and there is no reason to believe that the data subject has an overriding legitimate interest in not processing the data. Subsection 2 shall	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	5	
2.1.2.26(3)	Data processing for employment-related purposes	By derogation from Article 9 (1) of Regulation (EU) 2016/679, the processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 for employment-related purposes shall be permitted if it is necessary to exercise rights or comply with legal obligations derived from labour law, social security and social protection law, and there is no reason to believe that the data subject has an overriding legitimate interest in not processing the data. Subsection 2 shall	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	8	
2.1.2.26(4)	Data processing for employment-related	The processing of personal data, including special categories of personal data of employees for employment-related purposes, shall be permitted	Functional	Intersects With	Authority To Collect, Process, Store & Share	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit,	5	
2.1.2.26(4)	Data processing for employment-related purposes	The processing of personal data, including special categories of personal data of employees for employment-related purposes, shall be permitted on the basis of collective agreements. The negotiating partners shall comply with Article 88 (2) of Regulation (EU) 2016/679.	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	8	
2.1.2.26(5)	Data processing for employment-related	The controller must take appropriate measures to ensure compliance in particular with the principles for processing personal data described in	Functional	Subset Of	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all	10	
2.1.2.26(6)	Data processing for employment-related purposes	The rights of participation of staff councils shall remain unaffected.	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.26(7)	Data processing for employment-related purposes	Subsections 1 to 6 shall also apply when personal data, including special categories of personal data, of employees are processed without forming or being intended to form part of a filing system.	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	3	
2.1.2.26(8)	Data processing for employment-related	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.27	Data processing for purposes of scientific or	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.27(1)	Data processing for purposes of scientific or historical research and	ensure that persons authorized to use an automated processing system have access only to the personal data covered by their access authorization ("data access control");	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate	5	
2.1.2.27(2)	Data processing for purposes of scientific or historical research and for statistical purposes	The rights of data subjects provided in Articles 15, 16, 18 and 21 of Regulation (EU) 2016/679 shall be limited to the extent that these rights are likely to render impossible or seriously impair the achievement of the research or statistical purposes, and such limits are necessary for the fulfilment of the research or statistical purposes. Further, the right of access according to Article 15 of Regulation (EU) 2016/679 shall not apply if the data are necessary for purposes of scientific research and the provision of information would involve disproportionate effort.	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.27(3)	Data processing for purposes of scientific or historical research and for statistical purposes	In addition to the measures listed in Section 22 (2), special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 processed for scientific or historical research purposes or statistical purposes shall be rendered anonymous as soon as the research or statistical purpose allows, unless this conflicts with legitimate interests of the data subject. Until such time, the characteristics enabling information concerning personal or material circumstances to be attributed to an identified or identifiable individual shall be stored separately. They may be combined with the information only to the extent required by the research or statistical purpose.	Functional	Intersects With	Internal Use of Personal Data (PD) For Testing, Training and Research	PRI-05.1	Mechanisms exist to address the use of Personal Data (PD) for internal testing, training and research that: (1) Takes measures to limit or minimize the amount of PD used for internal testing, training and research purposes; and (2) Authorizes the use of PD when such information is required for internal testing, training and research.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.1.2.27(4)	Data processing for purposes of scientific or historical research and for statistical purposes	The controller may publish personal data only if the data subject has provided consent or if doing so is indispensable for the presentation of research findings on contemporary events.	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with: (1) Plain language explaining the potential data privacy risks of the authorization; (2) A means to decline the authorization; and (3) Necessary choice and consent-related criteria required by applicable statutory, regulatory and contractual obligations.	5	
2.1.2.28	Data processing for archiving purposes in the public interest	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.28(1)	Data processing for archiving purposes in the public interest	By derogation from Article 9 (1) of Regulation (EU) 2016/679, the processing of special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679 shall be permitted if necessary for archiving purposes in the public interest. The controller shall take appropriate and specific measures to safeguard the interests of the data subject in accordance with Section 22 (2), second sentence.	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
2.1.2.28(2)	Data processing for archiving purposes in the public interest	The right of access according to Article 15 of Regulation (EU) 2016/679 shall not apply if the archival material is not identified with the person's name or no information is given which would enable the archival material to be found with reasonable administrative effort.	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.28(3)	Data processing for archiving purposes in the public interest	The right of the data subject to rectification according to Article 16 of Regulation (EU) 2016/679 shall not apply if the personal data are processed for archiving purposes in the public interest. If the data subject disputes the accuracy of the personal data, he or she shall have the	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.28(4)	Data processing for archiving purposes in the public interest	The rights provided in Article 18 (1) (a), (b) and (d) and in Articles 20 and 21 of Regulation (EU) 2016/679 shall not apply as far as these rights are likely to render impossible or seriously impair the achievement of the archiving purposes in the public interest, and the exceptions are necessary to fulfil	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.29	Rights of the data subject and powers of the supervisory authorities in the case of secrecy	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.29(1)	Rights of the data subject and powers of the supervisory authorities in	In addition to the exceptions in Article 14 (5) of Regulation (EU) 2016/679, the obligation to provide information to the data subject according to Article 14 (1) to (4) of Regulation (EU) 2016/679 shall not apply as far as	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.29(2)	Rights of the data subject and powers of the supervisory authorities in	If in the context of a client-lawyer relationship the data of third persons are transferred to persons subject to a legal obligation of professional secrecy, the transferring body shall not be obligated to inform the data subject	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.29(3)	Rights of the data subject and powers of the supervisory authorities in	The supervisory authorities shall not have the investigative powers according to Article 58 (1) (e) and (f) of Regulation (EU) 2016/679 with regard to the persons listed in Section 203 (1), (2a) and (3) of the Criminal	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.30	Consumer loans	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2.1.2.31	Protection of commercial transactions in the case of scoring and credit reports	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2.2	Rights of the data subject	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.32	Information to be provided where personal data are collected from the data subject	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.32(1)	Information to be provided where personal data are collected from the data subject	In addition to the exception in Article 13 (4) of Regulation (EU) 2016/679, the obligation to provide information to the data subject according to Article 13 (3) of Regulation (EU) 2016/679 shall not apply if providing information about the planned further use	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.32(1)1	Information to be provided where personal data are collected from	concerns the further processing of data stored in analogue form, for which the controller directly contacts the data subject through the further processing; the purpose is compatible with the original purpose for which would, in the case of a public body, endanger the proper performance of tasks as referred to in Article 23 (1) (a) to (e) of Regulation (EU) 2016/679 for which the controller is responsible, and the controller's interests in not providing the information outweigh the interests of the data subject;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary	5	
2.2.32(1)2	Information to be provided where personal data are collected from the data subject		Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.32(1)3	Information to be provided where personal data are collected from the data subject	would endanger public security or order or would otherwise be detrimental to the welfare of the Federation or a Land, and the controller's interests in not providing the information outweigh the interests of the data subject;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.32(1)4	Information to be provided where personal data are collected from the data subject	would interfere with the establishment, exercise or defence of legal claims, and the controller's interests in not providing the information outweigh the interests of the data subject; or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.2.32(1)5	Information to be provided where personal data are collected from the data subject	would endanger a confidential transfer of data to public bodies	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.32(2)	Information to be provided where personal data are collected from the data subject	If information is not provided to the data subject pursuant to subsection 1, the controller shall take appropriate measures to protect the legitimate interests of the data subject, including providing the information referred to in Article 13 (1) and (2) of Regulation (EU) 2016/679 for the public in precise, transparent, understandable and easily accessible form in clear	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.32(3)	Information to be provided where personal data are collected from the data subject	If notification is not provided in the cases of subsection 1 because of a temporary obstacle, the controller shall meet the obligation to provide information, while taking into account the specific circumstances of processing, within an appropriate period after the obstacle has ceased to exist, but no later than two weeks.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.33	Information to be provided where personal data have not been obtained from the data subject	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.33(1)	Information to be provided where personal data have not been obtained from the data subject	In addition to the exception in Article 14 (5) of Regulation (EU) 2016/679 and in Section 29 (1), first sentence, the obligation to provide information to the data subject according to Article 14 (1), (2) and (4) of Regulation (EU) 2016/679 shall not apply if providing information and therefore the data subject's interest in receiving the information must not take precedence;	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.33(1)1	Information to be provided where personal data have not been obtained from the data subject	in the case of a public body	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.33(1)1(a)	Information to be provided where personal data have not been obtained from the data subject	would endanger the proper performance of tasks as referred to in Article 23 (1) (e) to (g) of Regulation (EU) 2016/679 for which the controller is responsible, or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.33(1)1(b)	Information to be provided where personal data have not been obtained from the data subject	would threaten the public security or order or otherwise be detrimental to the Federation or a Land,	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.33(1)2	Information to be provided where personal data have not been obtained from the data subject	in the case of a private body	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.33(1)2(a)	Information to be provided where personal data have not been obtained from the data subject	would interfere with the establishment, exercise or defence of legal claims, or processing includes data from contracts under private law and is intended to prevent harm from criminal offences, unless the data subject has an overriding legitimate interest in receiving the information; or	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	5	
2.2.33(1)3(b)	Information to be provided where personal data have not been obtained from the data subject	the responsible public body has determined with respect to the controller that disclosing the data would endanger public security or order or would otherwise be detrimental to the welfare of the Federation or a Land; in the case of data processing for purposes of law enforcement, no determination pursuant to the first half-sentence shall be required.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
2.2.33(2)	Information to be provided where personal data have not been obtained from the data subject	If information is not provided to the data subject pursuant to subsection 1, the controller shall take appropriate measures to protect the legitimate interests of the data subject, including providing the information referred to in Article 14 (1) and (2) of Regulation (EU) 2016/679 for the public in precise, transparent, understandable and easily accessible form in clear	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
2.2.33(2)	Information to be provided where personal data have not been obtained from the data subject	If information is not provided to the data subject pursuant to subsection 1, the controller shall take appropriate measures to protect the legitimate interests of the data subject, including providing the information referred to in Article 14 (1) and (2) of Regulation (EU) 2016/679 for the public in	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	5	
2.2.33(3)	Information to be provided where personal data have not been obtained from the data subject	If the provision of information relates to the transfer by public bodies of personal data to the authorities for the protection of the Constitution, the Federal Intelligence Service, the Military Counterintelligence Service and, as far as the security of the Federation is affected, other authorities of the	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34	Right of access by the data subject	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(1)	Right of access by the data subject	In addition to the exceptions in Section 27 (2), 28 (2) and 29 (1), second sentence, the data subject's right of access according to Article 15 of Regulation (EU) 2016/679 shall not apply if	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(1)1	Right of access by the data subject	the data subject shall not be informed pursuant to Section 33 (1) no. 1, no. 2 (b) or (3), or	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(1)2	Right of access by the data subject	the data and providing information would require a disproportionate effort, and appropriate technical and organizational measures make processing for other purposes impossible.	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(1)2(a)	Right of access by the data subject	were recorded only because they may not be erased due to legal or statutory provisions on retention, or	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(1)2(b)	Right of access by the data subject	only serve purposes of monitoring data protection or safeguarding data,	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(2)	Right of access by the data subject	The reasons for the refusal to provide information shall be documented. The data subject shall be informed of the reasons for refusing to provide information, unless providing the reasons in law and in fact on which the decision is based would undermine the intended purpose of refusing to provide the information. Data stored for the purpose of providing	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.2.34(2)	Right of access by the data subject	The reasons for the refusal to provide information shall be documented. The data subject shall be informed of the reasons for refusing to provide information, unless providing the reasons in law and in fact on which the decision is based would undermine the intended purpose of refusing to provide the information. Data stored for the purpose of providing	Functional	Intersects With	Justification To Reject Disclosure Requests	PRI-07.5	Mechanisms exist to document justifiable reasons for rejecting a data subject's access request for disclosure when the request is: (1) Harassing; (2) Repetitive; (3) Fraudulent;	5	
2.2.34(2)	Right of access by the data subject	The reasons for the refusal to provide information shall be documented. The data subject shall be informed of the reasons for refusing to provide information, unless providing the reasons in law and in fact on which the decision is based would undermine the intended purpose of refusing to provide the information. Data stored for the purpose of providing	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	5	
2.2.34(3)	Right of access by the data subject	If a public body of the Federation does not provide information to a data subject, such information shall be provided to the Federal Commissioner at the request of the data subject, unless the responsible supreme federal authority determines in the individual case that doing so would endanger the security of the Federation or a Land. The notification from the Federal Commissioner to the data subject with the results of the data protection assessment shall not permit any conclusions to be drawn concerning the	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.34(4)	Right of access by the data subject	The data subject shall have the right to information about personal data processed by a public body neither in automated nor in non-automated form and stored in a filing system only if the data subject provides information enabling the data to be located and if the effort required is not disproportionate to the data subject's interest in the information.	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.35	Right to erasure	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.35(1)	Right to erasure	If in the case of non-automated data processing erasure would be impossible or would involve a disproportionate effort due to the specific mode of storage and if the data subject's interest in erasure can be regarded as minimal, the data subject shall not have the right to erasure and the controller shall not be obligated to erase personal data in accordance with Article 17 (1) of Regulation (EU) 2016/679 in addition to the exceptions given in Article 17 (3) of Regulation (EU) 2016/679. In this	Functional	Intersects With	Right to Erasure	PRI-06.5	Mechanisms exist to maintain a process to erase a data subject's Personal Data (PD), in accordance with applicable laws, regulations and contractual obligations pertaining to the retention of their PD.	8	
2.2.35(2)	Right to erasure	In addition to Article 18 (1) (b) and (c) of Regulation (EU) 2016/679, subsection 1, first and second sentences shall apply accordingly in the case of Article 17 (1) (a) and (d) of Regulation (EU) 2016/679 as long and as far as the controller has reason to believe that erasure would adversely affect legitimate interests of the data subject. The controller shall inform the data subject of the restriction of processing if doing so is not	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	8	
2.2.35(3)	Right to erasure	In addition to Article 17 (3) (b) of Regulation (EU) 2016/679, subsection 1 shall apply accordingly in the case of Article 17 (1) (a) of Regulation (EU) 2016/679 not to be subject to a decision based solely on automated processing shall not apply if the decision is made in the context of the request of the data subject was fulfilled, or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD)	5	
2.2.36	Right to object	The right to object according to Article 21 (1) of Regulation (EU) 2016/679 with regard to a public body shall not apply if there is an urgent public interest in the processing which outweighs the interests of the data subject	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary	5	
2.2.37	Automated individual decision-making	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.37(1)	Automated individual decision-making, including profiling	In addition to the exceptions given in Article 22 (2) (a) and (c) of Regulation (EU) 2016/679, the right according to Article 22 (1) of Regulation (EU) 2016/679 not to be subject to a decision based solely on automated processing shall not apply if the decision is made in the context of the request of the data subject was fulfilled, or	Functional	No Relationship	N/A	N/A	N/A	0	
2.2.37(1)1	Automated individual decision-making	the decision is based on the application of binding rules of remuneration for therapeutic treatment and the controller takes suitable measures, in	Functional	Intersects With	Automated Decision-Making Technology	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or	5	
2.2.37(1)2	Automated individual decision-making	Decisions pursuant to subsection 1 may be based on the processing of health data as referred to in Article 4 no. 15 of Regulation (EU) 2016/679. The controller shall take appropriate and specific measures to safeguard the interests of the data subject in accordance with Section 22 (2), second sentence.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) For Data Subject Actions	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or substantially replaces, human decisionmaking, conforms with all applicable statutory, regulatory and/or contractual obligations.	5	
2.3	Obligations of controllers and processors	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.3.38	Data protection officers of private bodies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.3.38(1)	Data protection officers of private bodies	In addition to Article 37 (1) (b) and (c) of Regulation (EU) 2016/679, the controller and processor shall designate a data protection officer if they constantly employ as a rule at least 20 persons dealing with the automated processing of personal data. If the controller or processor undertake processing subject to a data protection impact assessment pursuant to Article 35 of Regulation (EU) 2016/679, or if they commercially process personal data for the purpose of transfer, or anonymized transfer or for purposes of market or opinion research, they shall designate a data protection officer regardless of the number of persons employed in processing.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
2.3.38(2)	Data protection officers of private bodies	Section 6 (4), (5), second sentence, and (6) shall apply, Section 6 (4) however shall apply only if designating a data protection officer is mandatory.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	3	
2.3.39	Accreditation	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2.4	Supervisory authorities for data processing by private bodies	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40	Supervisory authorities of the Länder	N/A	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.4.40(1)	Supervisory authorities of the Länder	The authorities pursuant to Land law shall monitor the application by private bodies of data protection legislation within the scope of Regulation (EU) 2016/679.	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(2)	Supervisory authorities of the Länder	If the controller or processor has more than one establishment in Germany, Article 4 no. 16 of Regulation (EU) 2016/679 shall apply accordingly in determining which supervisory authority is competent. If more than one authority considers itself competent or not competent, or	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(3)	Supervisory authorities of the Länder	The supervisory authority may process the data it has stored only for purposes of supervision; to this end, it may transfer data to other supervisory authorities. Processing for another purpose shall be permitted	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(3)1	Supervisory authorities of the Länder	it is obviously in the interest of the data subject and there is no reason to assume that the data subject would refuse consent if he or she were aware of the other purpose;	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(3)2	Supervisory authorities of the Länder	processing is necessary to prevent substantial harm to the common good or a threat to public security or to safeguard substantial concerns of the common good; or	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(3)3	Supervisory authorities of the Länder	processing is necessary to prosecute crimes or administrative offences, to carry out or enforce punishment or measures as referred to in Section 11 (1) no. 8 of the Criminal Code or educational or disciplinary measures as referred to in the Juvenile Court Act or to enforce fines.	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(4)	Supervisory authorities of the Länder	The bodies subject to monitoring and the persons responsible for their management shall provide a supervisory authority on request with the information necessary to perform their tasks. The person required to provide information may refuse to answer those questions which would expose him- or herself or a relative as referred to in Section 383 (1) nos. 1	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(5)	Supervisory authorities of the Länder	Persons assigned by the supervisory authority to monitor compliance with data protection legislation shall be authorized, as needed to perform their tasks, to enter the property and premises of the body and to have access to	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(6)	Supervisory authorities of the Länder	The supervisory authorities shall advise and support the data protection officers to meet their typical needs. They may demand the dismissal of a	Functional	No Relationship	N/A	N/A	N/A	0	
2.4.40(7)	Supervisory authorities of the Länder	The application of the Trade Regulation Code shall remain unaffected.	Functional	No Relationship	N/A	N/A	N/A	0	
2.5	Penalties	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2.6	Legal remedies	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3	Implementing provisions for processing for purposes in accordance	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.1	Scope, definitions and general principles for	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.1.45	Scope	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3.1.46	Definitions	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3.1.47	General principles for processing personal data	Personal data shall be	Functional	No Relationship	N/A	N/A	N/A	0	
3.1.47.1	General principles for processing personal data	processed lawfully and fairly;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary	8	
3.1.47.2	General principles for processing personal data	collected for specified, explicit and legitimate purposes and not processed in a manner that is incompatible with those purposes;	Functional	Intersects With	Restrict Collection, Processing & Sharing To Identified Purpose	PRI-04	Mechanisms exist to minimize the collection, processing and/or sharing of Personal Data (PD) to only what is adequate, relevant and limited to the purposes identified in the data privacy notice, including	8	
3.1.47.3	General principles for processing personal data	adequate, relevant and not excessive in relation to the purposes for which they are processed;	Functional	Intersects With	Restrict Collection, Processing & Sharing To Identified Purpose	PRI-04	Mechanisms exist to minimize the collection, processing and/or sharing of Personal Data (PD) to only what is adequate, relevant and limited to the purposes identified in the data privacy notice, including protections against collecting PD from minors without appropriate parental or legal guardian consent.	8	
3.1.47.4	General principles for processing personal data	accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay;	Functional	Intersects With	Personal Data (PD) Accuracy & Integrity	PRI-05.2	Mechanisms exist to ensure the accuracy and relevance of Personal Data (PD) throughout the information lifecycle by: (1) Keeping PD up-to-date; and (2) Remediating identified inaccuracies, as necessary.	8	
3.1.47.5	General principles for processing personal data	kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which they are processed;	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and	8	
3.1.47.6	General principles for processing personal data	processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures.	Functional	Intersects With	Restrict Collection, Processing & Sharing To Identified Purpose	PRI-04	Mechanisms exist to minimize the collection, processing and/or sharing of Personal Data (PD) to only what is adequate, relevant and limited to the purposes identified in the data privacy notice, including protections against collecting PD from minors without appropriate parental or legal guardian consent.	8	
3.2	Legal basis for processing personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.2.48	Processing of special categories of personal	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.2.48(1)	Processing of special categories of personal	The processing of special categories of personal data shall be allowed only where strictly necessary for the performance of the controller's tasks.	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.2.48(2)	Processing of special categories of personal data	If special categories of personal data are processed, appropriate safeguards for the legally protected interests of the data subject shall be implemented. Appropriate safeguards may be in particular	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.2.48(2)1	Processing of special categories of personal data	specific requirements for data security or data protection monitoring;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
3.2.48(2)2	Processing of special categories of personal data	special time limits within which data must be reviewed for relevance and erasure;	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-	8	
3.2.48(2)3	Processing of special categories of personal data	measures to increase awareness of staff involved in processing operations;	Functional	Intersects With	Security, Compliance & Resilience Awareness	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education	5	
3.2.48(2)4	Processing of special categories of personal data	restrictions on access to personal data within the controller;	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate	5	
3.2.48(2)5	Processing of special categories of personal data	separate processing of such data;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
3.2.48(2)6	Processing of special categories of personal data	the pseudonymization of personal data;	Functional	Intersects With	Data Anonymization	PRI-05.3	Mechanisms exist to mask sensitive and/or regulated data through data anonymization, pseudonymization, redaction and/or de-identification.	8	
3.2.48(2)7	Processing of special categories of personal data	the encryption of personal data; or	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	
3.2.48(2)8	Processing of special categories of personal data	specific codes of conduct to ensure lawful processing in case of transfer or processing for other purposes.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	
3.2.49	Processing for other purposes	Processing personal data for a purpose other than the one for which they were collected shall be permitted if the other purpose is one of the purposes listed in Section 45, the controller is authorized to process data for this purpose, and processing is necessary and proportionate to this purpose. Processing personal data for another purpose not listed in Section 45 shall be permitted if it is allowed by law.	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	5	
3.2.50	Processing for archiving, scientific and statistical purposes	Personal data may be processed in the context of purposes listed in Section 45 in archival, scientific or statistical form if doing so is in the public interest and appropriate safeguards for the legally protected interests of data subjects are implemented. Such safeguards may consist of rendering the personal data anonymous as quickly as possible, taking	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	5	
3.2.50	Processing for archiving, scientific and statistical purposes	Personal data may be processed in the context of purposes listed in Section 45 in archival, scientific or statistical form if doing so is in the public interest and appropriate safeguards for the legally protected	Functional	Intersects With	Data Anonymization	PRI-05.3	Mechanisms exist to mask sensitive and/or regulated data through data anonymization, pseudonymization, redaction and/or de-identification.	8	
3.2.51	Consent	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.2.51(1)	Consent	If personal data may be processed by law on the basis of consent, the controller must be able to present evidence of the data subject's consent.	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is	8	
3.2.51(2)	Consent	If the data subject's consent is given in the context of a written declaration which also concerns other matters, the request for consent shall be presented in a manner which is clearly distinguishable from the other matters, in an intelligible and easily accessible form, using clear and plain	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with:	5	
3.2.51(3)	Consent	The data subject shall have the right to withdraw his or her consent at any time. The withdrawal of consent shall not affect the lawfulness of processing based on consent before its withdrawal. The data subject shall be informed of this before giving consent.	Functional	Intersects With	Revoke Consent	PRI-03.4	Mechanisms exist to allow data subjects to revoke consent to collect, receive, process, store, transmit, share and/or update their Personal Data (PD).	8	
3.2.51(4)	Consent	Consent shall be effective only when based on the data subject's free decision. When assessing whether consent was freely given, the circumstances in which it was given must be taken into account. The data subject shall be informed of the intended purpose of the processing. If necessary in the individual case or on request, the data subject shall also be informed of the consequences of withholding consent.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations.	5	
3.2.51(5)	Consent	If special categories of personal data are to be processed, the consent must explicitly refer to these data.	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is	5	
3.2.51(5)	Consent	If special categories of personal data are to be processed, the consent must explicitly refer to these data.	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.2.52	Processing on instructions from the controller	Any person acting under the authority of the controller or of the processor who has access to personal data shall not process those data except on instructions from the controller, unless required to do so by law.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	5	
3.2.53	Confidentiality	Persons employed in data processing shall not process personal data without authorization (confidentiality). They shall be obligated when taking up their duties to maintain confidentiality. The obligation of confidentiality	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.2.54	Automated individual decision	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.2.54(1)	Automated individual decision	A decision based solely on automated processing which produces an adverse legal effect concerning the data subject or significantly affects him or her shall be permitted only when authorized by law.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) For Data Subject	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or substantially replaces, human decisionmaking, conforms with all	5	
3.2.54(2)	Automated individual decision	Decisions referred to in subsection 1 shall not be based on special categories of personal data unless suitable measures to safeguard the data subject's legally protected and legitimate interests are in place.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) For Data Subject Actions	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or substantially replaces, human decisionmaking, conforms with all applicable statutory, regulatory and/or contractual obligations.	5	
3.2.54(3)	Automated individual decision	Profiling that results in discrimination against natural persons on the basis of special categories of personal data shall be prohibited.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) For Data Subject Actions	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or substantially replaces, human decisionmaking, conforms with all applicable statutory, regulatory and/or contractual obligations.	5	
3.3	Rights of the data subject	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.55	General information on data processing	The controller shall provide general and publicly accessible information on	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.55.1	General information on data processing	the purposes of the processing,	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the	10	
3.3.55.2	General information on data processing	the rights of data subjects with regard to the processing of their personal data to access, rectification, erasure and restriction of processing,	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the	10	
3.3.55.3	General information on data processing	the names and contact details of the controller and the data protection officer,	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand,	10	
3.3.55.4	General information on data processing	the right to lodge a complaint with the Federal Commissioner, and	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
3.3.55.5	General information on data processing	the contact details of the Federal Commissioner.	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the	10	
3.3.56	Notification of data subjects	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.56(1)	Notification of data subjects	If special legislation provides for or requires notifying data subjects of the processing of their personal data, especially in the case of undercover operations, such notification shall include at least the following information:	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed;	5	
3.3.56(1)1	Notification of data subjects	the information listed in Section 55;	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand,	5	
3.3.56(1)2	Notification of data subjects	the legal basis for the processing;	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first	8	
3.3.56(1)2	Notification of data subjects	the legal basis for the processing;	Functional	Intersects With	Purpose Specification	PRI-02.1	Mechanisms exist to ensure data privacy notices identify the purpose(s) for which Personal Data (PD) is collected, received, processed, stored, transmitted and/or shared.	5	
3.3.56(1)3	Notification of data subjects	the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is	8	
3.3.56(1)4	Notification of data subjects	the categories of recipients of the personal data, if any;	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is	5	
3.3.56(1)5	Notification of data subjects	where necessary, further information, in particular where the personal data were collected without the knowledge of the data subject.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first	5	
3.3.56(2)	Notification of data subjects	In the cases of subsection 1, the controller may postpone, limit or refrain from notification if and so long as would otherwise be threatened, if the interest in avoiding these threats overrides the interest of the data subject in the information.	Functional	Intersects With	Personal Data (PD) Collection Methods	PRI-04.7	Mechanisms exist to ensure that Personal Data (PD) collection methods are: (1) In accordance with applicable statutory and/or regulatory requirements; (2) Appropriate for the circumstances of the data subject; (3) Unambiguous; and (4) Secure.	8	
3.3.56(2)1	Notification of data subjects	the performance of the tasks listed in Section 45,	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.56(2)2	Notification of data subjects	public security, or	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
3.3.56(2)3	Notification of data subjects	the legally protected interests of third parties	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
3.3.56(3)	Notification of data subjects	If the notification relates to the transfer of personal data to the authorities for the protection of the Constitution, the Federal Intelligence Service, the Military Counterintelligence Service and, as far as the security of the Federation is affected, other authorities of the Federal Ministry of Defence, such notification shall be permitted only with the approval of these bodies.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
3.3.56(4)	Notification of data subjects	Section 57 (7) shall apply accordingly in case of restriction pursuant to subsection 2.	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.57	Right of access	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.57(1)	Right of access	The controller shall inform data subjects on request whether data concerning them are being processed. Data subjects shall also have the right to information about	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
3.3.57(1)2	Right of access	the available information on the origin of the data;	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
3.3.57(1)3	Right of access	the purposes of and legal basis for the processing;	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
3.3.57(1)4	Right of access	the recipients or categories of recipients to whom the data have been disclosed, in particular recipients in third countries or international organizations;	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.57(1)4	Right of access	the recipients or categories of recipients to whom the data have been disclosed, in particular recipients in third countries or international organizations;	Functional	Intersects With	Accounting of Disclosures	PRI-14.1	Mechanisms exist to provide data subjects with an accounting of disclosures of their Personal Data (PD) controlled by: (1) The organization; and/or (2) Relevant third-parties that their PD was shared with.	8	
3.3.57(1)5	Right of access	the period for which the data will be stored, or if that is not possible, the criteria used to determine that period;	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
3.3.57(1)6	Right of access	the existence of the right to rectification or erasure of data or restriction of processing of data by the controller;	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
3.3.57(1)6	Right of access	the existence of the right to rectification or erasure of data or restriction of processing of data by the controller;	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized users of the PD.	8	
3.3.57(1)7	Right of access	the right pursuant to Section 60 to lodge a complaint with the Federal Commissioner, and	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	3	
3.3.57(1)8	Right of access	the contact details of the Federal Commissioner.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	3	
3.3.57(2)	Right of access	Subsection 1 shall not apply to personal data recorded only because they may not be erased due to legal or statutory provisions on retention, or only for purposes of monitoring data protection or safeguarding data, if providing information would require a disproportionate effort, and appropriate technical and organizational measures make processing for other purposes impossible.	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.57(3)	Right of access	No information shall be provided if the data subject does not provide information enabling the data to be located and if the effort required is therefore disproportionate to the data subject's interest in the information.	Functional	Intersects With	Data Subject Authentication	PRI-06.8	Mechanisms exist to utilize reasonable consumer expectations to verify a data subject's identity, prior to taking action to disclose, share, correct, amend and/or delete Personal Data (PD).	5	
3.3.57(4)	Right of access	Subject to the conditions of Section 56 (2), the controller may dispense with the provision of information pursuant to subsection 1, first sentence.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD).	5	
3.3.57(5)	Right of access	If the information to be provided relates to the transfer of personal data to the authorities for the protection of the Constitution, the Federal	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.57(6)	Right of access	The controller shall notify the data subject, without delay, in writing of any refusal or restriction of access. This shall not apply if providing this information would entail a threat as referred to in Section 56 (2). The notification pursuant to the first sentence shall include the reasons for the refusal or the restriction unless providing the reasons would undermine the intended purpose of the refusal or restriction of access.	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	8	
3.3.57(6)	Right of access	The controller shall notify the data subject, without delay, in writing of any refusal or restriction of access. This shall not apply if providing this information would entail a threat as referred to in Section 56 (2). The notification pursuant to the first sentence shall include the reasons for the refusal or the restriction unless providing the reasons would undermine the intended purpose of the refusal or restriction of access.	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	8	
3.3.57(7)	Right of access	If the data subject is notified pursuant to subsection 6 of the refusal or restriction of access, he or she may exercise his or her right of access also via the Federal Commissioner. The controller shall inform the data subject of this possibility and that, in accordance with Section 60, the data subject may lodge a complaint with the Federal Commissioner or seek a judicial remedy. If the data subject exercises his or her right pursuant to the first sentence, the information shall be provided to the Federal Commissioner at the request of the data subject, unless the responsible supreme federal authority determines in the individual case that doing so would threaten the security of the Federation or a Land. The Federal Commissioner shall at least inform the data subject that all necessary checks have been conducted or that the Federal Commissioner has conducted a review. This notification may include information as to whether violations of data protection law were found. The notification from the Federal Commissioner to the data subject shall not permit any conclusions to be drawn concerning the information held by the controller unless the latter agrees.	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.57(8)	Right of access	The controller shall document the factual or legal reasons on which the decision is based.	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	5	
3.3.57(8)	Right of access	The controller shall document the factual or legal reasons on which the decision is based.	Functional	Intersects With	Data Subject Communications Documentation	PRI-17.3	Mechanisms exist to maintain records of data subject requests and responses in accordance with an established documentation retention schedule that adheres to applicable statutory, regulatory and/or contractual obligations.	5	
3.3.58	Right to rectification and erasure and to restriction of processing	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.58(1)	Right to rectification and erasure and to restriction of processing	The data subject shall have the right to obtain from the controller without delay the rectification of inaccurate data concerning him or her. In particular in the case of statements or assessments, the question of accuracy is not relevant for the content of the statement or assessment. If the accuracy or inaccuracy of the data cannot be ascertained, the controller shall restrict processing instead of erasing the data. In this case, the controller shall inform the data subject before lifting the restriction of processing. The data subject may also ask to have incomplete personal data completed, if doing so is appropriate when taking into account the purposes of processing.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.58(1)	Right to rectification and erasure and to restriction of processing	The data subject shall have the right to obtain from the controller without delay the rectification of inaccurate data concerning him or her. In particular in the case of statements or assessments, the question of accuracy is not relevant for the content of the statement or assessment. If the accuracy or inaccuracy of the data cannot be ascertained, the controller shall restrict processing instead of erasing the data. In this case, the controller shall inform the data subject before lifting the restriction of processing. The data subject may also ask to have incomplete personal data completed, if doing so is appropriate when taking into account the purposes of processing.	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized users of the PD.	8	
3.3.58(1)	Right to rectification and erasure and to restriction of processing	The data subject shall have the right to obtain from the controller without delay the rectification of inaccurate data concerning him or her. In particular in the case of statements or assessments, the question of accuracy is not relevant for the content of the statement or assessment. If the accuracy or inaccuracy of the data cannot be ascertained, the controller shall restrict processing instead of erasing the data. In this case, the controller shall inform the data subject before lifting the restriction of processing. The data subject may also ask to have incomplete personal data completed, if doing so is appropriate when taking into account the purposes of processing.	Functional	Intersects With	Notice of Correction or Processing Change	PRI-06.2	Mechanisms exist to notify affected data subjects if their Personal Data (PD) has been corrected, amended or deleted.	5	
3.3.58(2)	Right to rectification and erasure and to restriction of processing	The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without delay where processing such data is unlawful, knowledge of the data is no longer necessary for the performance of tasks, or the data must be erased to comply with a legal obligation.	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	8	
3.3.58(2)	Right to rectification and erasure and to restriction of processing	The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without delay where processing such data is unlawful, knowledge of the data is no longer necessary for the performance of tasks, or the data must be erased to comply with a legal obligation.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
3.3.58(2)	Right to rectification and erasure and to restriction of processing	The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without delay where processing such data is unlawful, knowledge of the data is no longer necessary for the performance of tasks, or the data must be erased to comply with a legal obligation.	Functional	Intersects With	Right to Erasure	PRI-06.5	Mechanisms exist to maintain a process to erase a data subject's Personal Data (PD), in accordance with applicable laws, regulations and contractual obligations pertaining to the retention of their PD.	8	
3.3.58(3)	Right to rectification and erasure and to restriction of processing	Instead of erasure, the controller may restrict processing where Data subject to restricted processing pursuant to the first sentence may be processed only for the purpose which prevented their erasure.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.3.58(3)	Right to rectification and erasure and to restriction of processing	there is reason to assume that erasure would adversely affect legitimate interests of the data subject,	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.3.58(3)	Right to rectification and erasure and to restriction of processing	the data must be retained for the purposes of evidence in proceedings serving the purposes of Section 45, or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.3.58(3)	Right to rectification and erasure and to restriction of processing	erasure would be impossible or would involve a disproportionate effort due to the specific mode of storage.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.3.58(4)	Right to rectification and erasure and to restriction of processing	In automated filing systems, technical measures shall ensure that the restriction of processing is clearly recognizable and processing for other purposes is not possible without further examination.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.3.58(5)	Right to rectification and erasure and to restriction of processing	If the controller has rectified inaccurate data, he or she shall communicate the rectification to the body from which he or she received the personal data. In cases of rectification, erasure or restriction of processing pursuant to subsections 1 to 3, the controller shall inform recipients to whom the data were transferred about these measures. The recipient shall rectify or erase the data or restrict their processing.	Functional	Intersects With	Notice of Correction or Processing Change	PRI-06.2	Mechanisms exist to notify affected data subjects if their Personal Data (PD) has been corrected, amended or deleted.	8	
3.3.58(5)	Right to rectification and erasure and to restriction of processing	If the controller has rectified inaccurate data, he or she shall communicate the rectification to the body from which he or she received the personal data. In cases of rectification, erasure or restriction of processing pursuant to subsections 1 to 3, the controller shall inform recipients to whom the data were transferred about these measures. The recipient shall rectify or erase the data or restrict their processing.	Functional	Intersects With	Obligation To Inform Third-Parties	PRI-07.3	Mechanisms exist to inform applicable third-parties of any modification, deletion or other change that affects shared Personal Data (PD).	8	
3.3.58(6)	Right to rectification and erasure and to restriction of processing	The controller shall inform the data subject in writing of any refusal to rectify or erase personal data or restrict its processing. This shall not apply if providing this information would entail a threat as referred to in Section 56 (2). The information pursuant to the first sentence shall include the	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	8	
3.3.58(7)	Right to rectification and erasure and to restriction of processing	Section 57 (7) and (8) shall apply accordingly.	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.59	Modalities for exercising the rights of the data subject	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.59(1)	Modalities for exercising the rights of the data subject	The controller shall communicate with data subjects in a concise, intelligible and easily accessible form, using clear and plain language. Regardless of special formal requirements, when responding to requests, the controller shall provide the information in the same form as the request.	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	8	
3.3.59(2)	Modalities for exercising the rights of the data subject	When responding to requests, without prejudice to Section 57 (6) and Section 58 (6) the controller shall inform the data subject in writing about the follow-up to his or her request without delay.	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	5	
3.3.59(2)	Modalities for exercising the rights of the data subject	When responding to requests, without prejudice to Section 57 (6) and Section 58 (6) the controller shall inform the data subject in writing about the follow-up to his or her request without delay.	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	8	
3.3.59(3)	Modalities for exercising the rights of the data subject	Information provided pursuant to Section 55, any communication made pursuant to Sections 56 and 66, and requests processed pursuant to Sections 57 and 58 shall be free of charge. Where a request pursuant to Sections 57 and 58 is manifestly unfounded or excessive, the controller may charge a reasonable fee based on its administrative costs, or may refuse to act on the request. In this case, the controller must be able to demonstrate the manifestly unfounded or excessive character of the request.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
3.3.59(3)	Modalities for exercising the rights of the data subject	Information provided pursuant to Section 55, any communication made pursuant to Sections 56 and 66, and requests processed pursuant to Sections 57 and 58 shall be free of charge. Where a request pursuant to Sections 57 and 58 is manifestly unfounded or excessive, the controller may charge a reasonable fee based on its administrative costs, or may refuse to act on the request. In this case, the controller must be able to demonstrate the manifestly unfounded or excessive character of the request.	Functional	Intersects With	Product or Service Delivery Restrictions	PRI-03.5	Mechanisms exist to prevent discrimination against a data subject for exercising their legal rights pertaining to modifying or revoking consent, including prohibiting: (1) Refusing products and/or services; (2) Charging different rates for goods and/or services; and	3	
3.3.59(4)	Modalities for exercising the rights of the data subject	Where the controller has reasonable doubts concerning the identity of a data subject making the request pursuant to Sections 57 or 58, the controller may request the provision of additional information necessary to confirm the identity of the data subject.	Functional	Intersects With	Data Subject Authentication	PRI-06.8	Mechanisms exist to utilize reasonable consumer expectations to verify a data subject's identity, prior to taking action to disclose, share, correct, amend and/or delete Personal Data (PD).	3	
3.3.59(4)	Modalities for exercising the rights of the data subject	Where the controller has reasonable doubts concerning the identity of a data subject making the request pursuant to Sections 57 or 58, the controller may request the provision of additional information necessary to confirm the identity of the data subject.	Functional	Intersects With	Justification To Reject Disclosure Requests	PRI-07.5	Mechanisms exist to document justifiable reasons for rejecting a data subject's access request for disclosure when the request is: (1) Harassing; (2) Repetitive.	5	
3.3.60	Right to lodge a complaint with the Federal Commissioner	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.60(1)	Right to lodge a complaint with the Federal Commissioner	Without prejudice to any other administrative or judicial remedy, every data subject shall have the right to lodge a complaint with the Federal Commissioner, if the data subject believes that the processing by public bodies of personal data relating to him or her for the purposes listed in this Act and other data protection provisions. The data subject shall	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.60(2)	Right to lodge a complaint with the Federal Commissioner	If a complaint about processing is lodged with the Federal Commissioner instead of the competent supervisory authority in another Member State of the European Union, the Federal Commissioner shall transmit the complaint to the competent supervisory authority without delay. In this See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3.3.61	Legal remedies against decisions of the Federal Commissioner or if he or she fails to take action	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4	Obligations of controllers and processors	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.62	Processing carried out on behalf of a controller	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.62(1)	Processing carried out on behalf of a controller	Where personal data are processed by other persons or bodies on behalf of a controller, the controller shall ensure compliance with the provisions of this Act and other data protection provisions. The data subject shall	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(2)	Processing carried out on behalf of a controller	A controller may use only processors providing sufficient guarantees to implement appropriate technical and organizational measures in such a manner that the processing will meet the requirements of the law and	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(3)	Processing carried out on behalf of a controller	Processors shall not engage other processors without prior written authorization by the controller. If the controller has given the processor general authorization to engage other processors, the processor shall inform the controller of any intended changes concerning the addition or replacement of other processors. In this case, the controller may object to	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4.62(3)	Processing carried out on behalf of a controller	Processors shall not engage other processors without prior written authorization by the controller. If the controller has given the processor general authorization to engage other processors, the processor shall inform the controller of any intended changes concerning the addition or replacement of other processors. In this case, the controller may object to the addition or replacement of other processors.	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(4)	Processing carried out on behalf of a controller	Where a processor engages another processor, the former shall impose on the latter the same data protection obligations as set out in the contract between the controller and the processor as referred to in subsection 5 if these obligations are not already binding for the latter processor because of other legislation. Where that other processor fails to fulfil these obligations, the initial processor shall remain fully liable to the controller for the performance of that other processor's obligations.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(4)	Processing carried out on behalf of a controller	Where a processor engages another processor, the former shall impose on the latter the same data protection obligations as set out in the contract between the controller and the processor as referred to in subsection 5 if these obligations are not already binding for the latter processor because of other legislation. Where that other processor fails to fulfil these obligations, the initial processor shall remain fully liable to the controller for the performance of that other processor's obligations.	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)	Processing carried out on behalf of a controller	Processing by a processor shall be governed by a contract or other legal instrument that is binding on the processor with regard to the controller and that sets out the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects and the obligations and rights of the controller. That contract or other legal instrument shall stipulate, in particular, that the processor	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(5)	Processing carried out on behalf of a controller	Processing by a processor shall be governed by a contract or other legal instrument that is binding on the processor with regard to the controller and that sets out the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects and the obligations and rights of the controller. That contract or other legal instrument shall stipulate, in particular, that the processor	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)1	Processing carried out on behalf of a controller	acts only on instructions from the controller; if the processor believes that an instruction is unlawful, the processor shall inform the controller without delay;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(5)1	Processing carried out on behalf of a controller	acts only on instructions from the controller; if the processor believes that an instruction is unlawful, the processor shall inform the controller without delay;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)2	Processing carried out on behalf of a controller	ensures that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(5)2	Processing carried out on behalf of a controller	ensures that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
3.4.62(5)2	Processing carried out on behalf of a controller	ensures that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)3	Processing carried out on behalf of a controller	assists the controller by any appropriate means to ensure compliance with the provisions on the data subject's rights;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(5)3	Processing carried out on behalf of a controller	assists the controller by any appropriate means to ensure compliance with the provisions on the data subject's rights;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)4	Processing carried out on behalf of a controller	at the choice of the controller, deletes or returns all the personal data to the controller after the end of the provision of data processing services, and deletes existing copies unless law requires storage of the personal data;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(5)4	Processing carried out on behalf of a controller	at the choice of the controller, deletes or returns all the personal data to the controller after the end of the provision of data processing services, and deletes existing copies unless law requires storage of the personal data;	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law;	8	
3.4.62(5)4	Processing carried out on behalf of a controller	at the choice of the controller, deletes or returns all the personal data to the controller after the end of the provision of data processing services, and deletes existing copies unless law requires storage of the personal data;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)5	Processing carried out on behalf of a controller	makes available to the controller all information necessary, in particular the logs kept in accordance with Section 76, to demonstrate compliance with these obligations;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	8	
3.4.62(5)5	Processing carried out on behalf of a controller	makes available to the controller all information necessary, in particular the logs kept in accordance with Section 76, to demonstrate compliance with these obligations;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)6	Processing carried out on behalf of a controller	allows for and contributes to audits conducted by the controller or another auditor mandated by the controller;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.62(5)6	Processing carried out on behalf of a controller	allows for and contributes to audits conducted by the controller or another auditor mandated by the controller;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
3.4.62(5)7	Processing carried out on behalf of a controller	complies with the conditions referred to in subsections 3 and 4 for engaging another processor;	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4.62(5)7	Processing carried out on behalf of a controller	complies with the conditions referred to in subsections 3 and 4 for engaging another processor;	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	8	
3.4.62(5)8	Processing carried out on behalf of a controller	takes all measures required pursuant to Section 64; and	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights	5	
3.4.62(5)9	Processing carried out on behalf of a controller	assists the controller in ensuring compliance with the obligations pursuant to Sections 64 to 67 and 69 taking into account the nature of processing and the information available to the processor.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	8	
3.4.62(5)9	Processing carried out on behalf of a controller	assists the controller in ensuring compliance with the obligations pursuant to Sections 64 to 67 and 69 taking into account the nature of processing and the information available to the processor.	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	8	
3.4.62(6)	Processing carried out on behalf of a controller	The contract referred to in subsection 5 shall be in writing or in an electronic form.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights	5	
3.4.62(7)	Processing carried out on behalf of a controller	A processor that determines, in violation of this provision, the purposes and means of processing, shall be considered a controller in respect of that processing.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.4.63	Joint controllers	Where two or more controllers jointly determine the purposes and means of processing, they shall be considered joint controllers. Joint controllers shall determine their respective tasks and responsibilities under data protection law in a transparent manner in an agreement, unless these tasks and responsibilities are already determined by law. In particular, this	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights	8	
3.4.63	Joint controllers	Where two or more controllers jointly determine the purposes and means of processing, they shall be considered joint controllers. Joint controllers shall determine their respective tasks and responsibilities under data protection law in a transparent manner in an agreement, unless these tasks and responsibilities are already determined by law. In particular, this	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	8	
3.4.64	Requirements for the security of data processing	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.64(1)	Requirements for the security of data processing	The controller and the processor, taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of the processing as well as the risk of varying likelihood and severity for the legally protected interests of natural persons, shall implement the measures referred to in subsection 1 may include pseudonymization and encryption of personal data, if such means are possible in view of the purposes of processing. The measures pursuant to subsection 1 should ensure	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(2)	Requirements for the security of data processing	The measures referred to in subsection 1 may include pseudonymization and encryption of personal data, if such means are possible in view of the purposes of processing. The measures pursuant to subsection 1 should ensure	Functional	Intersects With	De-Identification (Anonymization)	DCH-23	Mechanisms exist to anonymize data by removing Personal Data (PD) from datasets.	5	
3.4.64(2)1	Requirements for the security of data processing	the ongoing confidentiality, integrity, availability and resilience of processing systems and services in connection with processing; and	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(2)2	Requirements for the security of data processing	the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident.	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)	Requirements for the security of data processing	In respect of automated processing, the controller and processor, following an evaluation of the risks, shall implement measures designed to A purpose pursuant to the first sentence, nos. 2 to 5 may be achieved in deny unauthorized persons access to processing equipment used for processing ("equipment access control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)1	Requirements for the security of data processing	prevent the unauthorized reading, copying, modification or erasure of data media ("data media control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
3.4.64(3)2	Requirements for the security of data processing	prevent the unauthorized input of personal data and the unauthorized inspection, modification or deletion of stored personal data ("storage control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
3.4.64(3)4	Requirements for the security of data processing	prevent the use of automated processing systems by unauthorized persons using data communication equipment ("user control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)5	Requirements for the security of data processing	ensure that persons authorized to use an automated processing system have access only to the personal data covered by their access authorization ("data access control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)6	Requirements for the security of data processing	ensure that it is possible to verify and establish the bodies to which personal data have been or may be transmitted or made available using data communication equipment ("communication control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)7	Requirements for the security of data processing	ensure that it is subsequently possible to verify and establish which personal data have been input into automated processing systems and when and by whom the personal data were input ("input control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
3.4.64(3)8	Requirements for the security of data processing	ensure that the confidentiality and integrity of personal data are protected during transfers of personal data or during transport of data media ("transport control");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
3.4.64(3)9	Requirements for the security of data processing	ensure that installed systems may, in the case of interruption, be restored ("recovery");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)10	Requirements for the security of data processing	ensure that all system functions perform and that the appearance of faults in the functions is reported ("reliability");	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4.64(3)11	Requirements for the security of data processing	ensure that stored personal data cannot be corrupted by means of a malfunctioning of the system ('integrity');	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)12	Requirements for the security of data processing	ensure that personal data processed on behalf of the controller can only be processed in compliance with the controller's instructions ('processing control');	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.64(3)13	Requirements for the security of data processing	ensure that personal data are protected against loss and destruction ('availability control');	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	8	
3.4.64(3)14	Requirements for the security of data processing	ensure that personal data collected for different purposes can be processed separately ('separability').	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
3.4.65	Notifying the Federal Commissioner of a personal data breach	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.65(1)	Notifying the Federal Commissioner of a personal data breach	In the case of a personal data breach, the controller shall notify the Federal Commissioner without delay and, if possible, not later than 72 hours after having become aware of it, of the personal data breach, unless the personal data breach is unlikely to result in a risk to the legally	Functional	Intersects With	Data Breach	IRO-04.1	Mechanisms exist to address data breaches, or other incidents involving the unauthorized disclosure of sensitive or regulated data, according to applicable laws, regulations and contractual obligations.	8	
3.4.65(1)	Notifying the Federal Commissioner of a personal data breach	In the case of a personal data breach, the controller shall notify the Federal Commissioner without delay and, if possible, not later than 72 hours after having become aware of it, of the personal data breach, unless the personal data breach is unlikely to result in a risk to the legally	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	8	
3.4.65(2)	Notifying the Federal Commissioner of a personal data breach	A processor shall notify the controller of a personal data breach without delay.	Functional	Intersects With	Data Breach	IRO-04.1	Mechanisms exist to address data breaches, or other incidents involving the unauthorized disclosure of sensitive or regulated data, according to applicable laws, regulations and contractual obligations.	8	
3.4.65(2)	Notifying the Federal Commissioner of a personal data breach	A processor shall notify the controller of a personal data breach without delay.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5	
3.4.65(3)	Notifying the Federal Commissioner of a personal data breach	The notification referred to in subsection 1 shall include at least the following information:	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(3)1	Notifying the Federal Commissioner of a personal data breach	a description of the nature of the personal data breach including, where possible, the categories and approximate number of data subjects concerned and the categories and approximate number of personal data records concerned;	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(3)2	Notifying the Federal Commissioner of a personal data breach	the name and contact details of the data protection officer or other contact point where more information can be obtained;	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(3)3	Notifying the Federal Commissioner of a personal data breach	a description of the likely consequences of the personal data breach; and	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(3)4	Notifying the Federal Commissioner of a personal data breach	a description of the measures taken or proposed by the controller to address the personal data breach, including measures to mitigate its possible adverse effects.	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(4)	Notifying the Federal Commissioner of a personal data breach	If it is not possible to provide the information pursuant to subsection 3 with the notification, the controller shall provide this information as soon as it is available	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(5)	Notifying the Federal Commissioner of a personal data breach	The controller shall document any personal data breaches. This documentation shall include all the facts relating to the personal data breach, its effects and the remedial action taken.	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(6)	Notifying the Federal Commissioner of a personal data breach	If the personal data breach involves personal data that have been transmitted by or to a controller in another Member State of the European Union, the information referred to in subsection 3 shall be communicated to the controller in that Member State without delay.	Functional	Subset Of	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	10	
3.4.65(7)	Notifying the Federal Commissioner of a personal data breach	Section 42 (4) shall apply accordingly.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.65(8)	Notifying the Federal Commissioner of a personal data breach	Additional obligations of the controller regarding notifications of personal data breaches shall remain unaffected.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66	Notifying data subjects affected by a personal data breach	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66(1)	Notifying data subjects affected by a personal data breach	If a personal data breach is likely to result in a substantial risk to the legally protected interests of natural persons, the controller shall notify the data subject of the personal data breach without delay.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
3.4.66(2)	Notifying data subjects affected by a personal data breach	The notification of the data subject pursuant to subsection 1 shall describe in clear and plain language the nature of the personal data breach and contain at least the information and measures referred to in Section 65 (3) nos. 2 to 4.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
3.4.66(3)	Notifying data subjects affected by a personal data breach	Notification shall not be required if any of the following conditions are met:	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66(3)1	Notifying data subjects affected by a personal data breach	the controller has implemented appropriate technical and organizational protection measures, and those measures were applied to the personal data affected by the personal data breach, in particular those that render	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66(3)2	Notifying data subjects affected by a personal data breach	the controller has taken subsequent measures which ensure that the substantial risk referred to in subsection 1 is no longer likely to exist;	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66(3)3	Notifying data subjects affected by a personal data breach	it would involve a disproportionate effort; in this case, a public communication shall be made or a similar measure taken to inform the data subjects in an equally effective manner.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66(4)	Notifying data subjects affected by a personal data breach	If the controller has not informed the data subjects of a personal data breach, the Federal Commissioner may formally determine that, in his or her opinion, the conditions referred to in subsection 3 have not been met.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.66(5)	Notifying data subjects affected by a personal data breach	The notification of data subjects pursuant to subsection 1 may be delayed, restricted or omitted under the conditions referred to in Section 56 (2) unless the interests of the data subjects outweigh those of the controller	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4.66(6)	Notifying data subjects affected by a personal data breach	Section 42 (4) shall apply accordingly.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.67	Conducting a data protection impact assessment	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.67(1)	Conducting a data protection impact assessment	Where a type of processing in particular using new technologies, and taking into account the nature, scope, context and purposes of the processing, is likely to result in a substantial risk to the legally protected	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and	5	
3.4.67(2)	Conducting a data protection impact assessment	A joint assessment may address a set of similar processing operations that present similar substantial risks.	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
3.4.67(3)	Conducting a data protection impact assessment	The controller shall involve the Federal Commissioner in carrying out the impact assessment.	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and	5	
3.4.67(4)	Conducting a data protection impact assessment	The impact assessment shall take the rights of the data subjects affected by the processing into account and shall contain at least the following:	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and	5	
3.4.67(4)1	Conducting a data protection impact assessment	a systematic description of the envisaged processing operations and the purposes of the processing;	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and	5	
3.4.67(4)2	Conducting a data protection impact assessment	an assessment of the necessity and proportionality of the processing operations in relation to their purposes;	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
3.4.67(4)3	Conducting a data protection impact assessment	an assessment of the risks to the legally protected interests of the data subjects; and	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
3.4.67(4)4	Conducting a data protection impact assessment	the measures envisaged to address the risks, including safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with the law.	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and	8	
3.4.67(5)	Conducting a data protection impact assessment	Where necessary, the controller shall carry out a review to assess whether processing is performed in accordance with the data protection impact assessment.	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	8	
3.4.68	Cooperation with the Federal Commissioner	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69	Prior consultation of the Federal Commissioner	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(1)	Prior consultation of the Federal Commissioner	The controller shall consult the supervisory authority prior to processing which will form part of a new filing system if The Federal Commissioner may draw up a list of the processing operations which are subject to prior consultation pursuant to the first sentence.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(1)1	Prior consultation of the Federal Commissioner	a data protection impact assessment pursuant to Section 67 indicates that the processing would result in a substantial risk to the legally protected interests of data subjects in the absence of measures taken by the controller to mitigate the risk; or	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(1)2	Prior consultation of the Federal Commissioner	the type of processing, in particular, where using new technologies, mechanisms or procedures, involves a substantial risk to the legally protected interests of data subjects.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(2)	Prior consultation of the Federal Commissioner	In the case of subsection 1, the Federal Commissioner shall be presented with On request, the Federal Commissioner shall be given any other	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(2)1	Prior consultation of the Federal Commissioner	the data protection impact assessment carried out pursuant to Section 67;	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(2)2	Prior consultation of the Federal Commissioner	where applicable, information on the respective responsibilities of the controller, joint controllers and processors involved in the processing;	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(2)3	Prior consultation of the Federal Commissioner	information on the purposes and means of the envisaged processing;	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(2)4	Prior consultation of the Federal Commissioner	information on the measures and safeguards intended to protect the legally protected interests of the data subjects; and	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(2)5	Prior consultation of the Federal Commissioner	the name and contact details of the data protection officer.	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(3)	Prior consultation of the Federal Commissioner	If the Federal Commissioner believes that the planned processing would violate the law, in particular because the controller has not sufficiently identified the risk or has not taken sufficient measures to mitigate the risk, he or she may provide, within a period of up to six weeks of receipt of the	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.69(4)	Prior consultation of the Federal Commissioner	If the envisaged processing has substantial significance for the controller's performance of tasks and is therefore especially urgent, the controller may initiate processing after the consultation has started but before the period referred to in subsection 3, first sentence, has expired. In this case, the	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.70	Records of processing activities	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.70(1)	Records of processing activities	The controller shall keep a record of all categories of processing activities under its responsibility. This record shall contain all of the following information:	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory	5	
3.4.70(1)1	Records of processing activities	the name and contact details of the controller and, where applicable, of the joint controller; and the name and contact details of the data	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	3	
3.4.70(1)2	Records of processing activities	the purposes of the processing;	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	5	
3.4.70(1)3	Records of processing activities	the categories of recipients to whom the personal data have been or are to be disclosed;	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	3	
3.4.70(1)4	Records of processing activities	a description of the categories of data subjects and of the categories of personal data;	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory	5	
3.4.70(1)5	Records of processing activities	where applicable, the use of profiling;	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient	3	
3.4.70(1)6	Records of processing activities	where applicable, the categories of transfers of personal data to bodies in a third country or to an international organization;	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	3	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Germany - Federal Data Protection Act (2017)**

Focal Document URL: https://www.gesetze-im-internet.de/englisch_bdsge/englisch_bdsge.pdf

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-emea-deu-fdpa-2017.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4.70(1)7	Records of processing activities	information about the legal basis for the processing;	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,		
3.4.70(1)8	Records of processing activities	the envisaged time limits for the erasure or for a review of the need to store the various categories of personal data; and	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	5	
3.4.70(1)9	Records of processing activities	a general description of the technical and organizational security measures referred to in Section 64.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	3	
3.4.70(2)	Records of processing activities	The processor shall maintain a record of all categories of processing activities carried out on behalf of a controller, containing	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal	5	
3.4.70(2)1	Records of processing activities	the name and contact details of the processor, of each controller on behalf of which the processor is acting and, where applicable, the data protection where applicable, transfers of personal data to bodies in a third country or to an international organization, including the identification of that third country or international organization; and	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	5	
3.4.70(2)2	Records of processing activities		Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.4.70(2)3	Records of processing activities	a general description of the technical and organizational security measures according to Section 64.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.4.70(4)	Records of processing activities	Controllers and processors shall make these records available to the Federal Commissioner on request.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	5	
3.4.71	Data protection by design and by default	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.71(1)	Data protection by design and by default	The controller, both at the time the means of processing are determined and at the time of the processing itself, shall take appropriate measures to implement data protection principles, such as data minimization, in an effective manner, to ensure compliance with legal requirements and to protect the rights of data subjects. In doing so, the controller shall take into	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	
3.4.71(2)	Data protection by design and by default	The controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data which are necessary for each specific purpose of the processing are processed. That applies to the amount of data collected, the extent of their processing, the period of their storage and their accessibility. In particular, the measures	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
3.4.72	Distinction between different categories of data subjects	When processing personal data, the controller shall, as far as possible, make a clear distinction between different categories of data subjects. This applies in particular to the following categories:	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.72.1	Distinction between different categories of data subjects	persons with regard to whom there are serious grounds for believing that they have committed a criminal offence;	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.72.2	Distinction between different categories of data subjects	persons with regard to whom there are serious grounds for believing that they are about to commit a criminal offence;	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.72.3	Distinction between different categories of data subjects	persons convicted of a criminal offence;	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.72.4	Distinction between different categories of data subjects	victims of a criminal offence or persons with regard to whom certain facts indicate that they could be the victim of a criminal offence; and	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.72.5	Distinction between different categories of data subjects	other persons, such as witnesses, persons who can provide information, or contacts or associates of the persons referred to in nos. 1 to 4.	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.73	Distinction between facts and personal assessments	In processing, the controller shall distinguish, as far as possible, personal data based on facts from personal data based on personal assessments. To this end, the controller shall identify evaluations based on personal assessments as such, as far as possible and reasonable in the context of the processing in question. It must also be possible to determine which	Functional	Intersects With	Personal Data (PD) Categories	PRI-05.7	Mechanisms exist to define and implement data handling and protection requirements for specific categories of sensitive Personal Data (PD).	5	
3.4.74	Procedures for data transfers	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.74(1)	Procedures for data transfers	The controller shall take appropriate measures to ensure that personal data which are inaccurate or no longer up to date are not transmitted or otherwise made available. To that end, the controller shall, as far as possible with reasonable effort, verify the quality of the data before they are transmitted or made available. The controller shall also, as far as	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.4.74(1)	Procedures for data transfers	The controller shall take appropriate measures to ensure that personal data which are inaccurate or no longer up to date are not transmitted or otherwise made available. To that end, the controller shall, as far as possible with reasonable effort, verify the quality of the data before they are transmitted or made available. The controller shall also, as far as	Functional	Intersects With	Personal Data (PD) Accuracy & Integrity	PRI-05.2	Mechanisms exist to ensure the accuracy and relevance of Personal Data (PD) throughout the information lifecycle by: (1) Keeping PD up-to-date; and (2) Remediating identified inaccuracies, as necessary.	5	
3.4.74(2)	Procedures for data transfers	If the processing of personal data is subject to special conditions, in transmissions of data the transmitting body shall inform the recipient of these conditions and the requirement to respect them. The obligation of providing information may be met by marking the data accordingly.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.4.74(2)	Procedures for data transfers	If the processing of personal data is subject to special conditions, in transmissions of data the transmitting body shall inform the recipient of these conditions and the requirement to respect them. The obligation of providing information may be met by marking the data accordingly.	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	5	
3.4.74(3)	Procedures for data transfers	The transmitting body shall not apply conditions to recipients in other Member States of the European Union or to agencies, offices and bodies	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.75	Rectification and erasure of personal data and restriction of processing	N/A	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4.75(1)	Rectification and erasure of personal data and restriction of processing	The controller shall rectify inaccurate personal data.	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized users of the PD.	8	
3.4.75(2)	Rectification and erasure of personal data and restriction of processing	The controller shall erase personal data without delay if their processing is unlawful, they must be erased to comply with a legal obligation, or knowledge of the data is no longer necessary for the controller to perform	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as	5	
3.4.75(3)	Rectification and erasure of personal data and restriction of processing	Section 58 (3) to (5) shall apply accordingly. The recipient shall also be informed if inaccurate personal data have been transmitted, or if personal data have been transmitted unlawfully.	Functional	Intersects With	Communicating Processing Changes	PRI-03.11	Mechanisms exist to notify data subjects of processing changes affecting their Personal Data (PD), including: (1) Erasure of PD;	8	
3.4.75(3)	Rectification and erasure of personal data and restriction of processing	Section 58 (3) to (5) shall apply accordingly. The recipient shall also be informed if inaccurate personal data have been transmitted, or if personal data have been transmitted unlawfully.	Functional	Intersects With	Notice of Correction or Processing Change	PRI-06.2	Mechanisms exist to notify affected data subjects if their Personal Data (PD) has been corrected, amended or deleted.	8	
3.4.75(4)	Rectification and erasure of personal data and restriction of processing	Without prejudice to any time limits for storing or erasing data defined in law, the controller shall provide for appropriate time limits for the erasure of personal data or for a periodic review of the need for the storage of	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as	8	
3.4.76	Logging	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.4.76(1)	Logging	Controllers and processors shall provide for logs to be kept for at least the following processing operations in automated processing systems:	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient	5	
3.4.76(1)1	Logging	collection,	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.4.76(1)2	Logging	alteration,	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage,	5	
3.4.76(1)3	Logging	consultation,	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.4.76(1)4	Logging	disclosure including transfers,	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.4.76(1)5	Logging	combination, and	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory	5	
3.4.76(1)6	Logging	erasure.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory	5	
3.4.76(2)	Logging	The logs of consultation and disclosure must make it possible to ascertain the justification, date and time of such operations and, as far as possible, the identity of the person who consulted or disclosed personal data, and the identity of the recipients of the data.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	8	
3.4.76(3)	Logging	The logs may be used only by the data protection officer, the Federal Commissioner or the data subject to verify the lawfulness of the processing; and for self-monitoring, ensuring the integrity and security of the personal data, and for criminal proceedings.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory	5	
3.4.76(4)	Logging	The log data shall be erased at the end of the year following the year in which they were generated.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.4.76(5)	Logging	The controller and the processor shall make the logs available to the Federal Commissioner on request.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	8	
3.4.77	Confidential reporting of violations	The controller shall ensure that it is able to receive confidential reports of violations of data protection law which have occurred in its area of responsibility.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
3.5	Transfers of data to third countries and to international organizations	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.5.78	General Requirements	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.5.78(1)	General Requirements	If all other conditions applicable to data transfers are met, the transfer of personal data to bodies in third countries or to international organizations the body or international organization is responsible for the purposes referred to in Section 45, and	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged	5	
3.5.78(1)1	General Requirements		Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.5.78(1)2	General Requirements	the European Commission has adopted an adequacy decision pursuant to Article 36 (3) of Directive (EU) 2016/680.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.5.78(2)	General Requirements	No transfer of personal data shall be permitted, despite an adequacy decision as referred to in subsection 1 no. 2 and the public interest in the data transfer to be taken into account, if in the individual case it cannot be ensured that the data will be handled appropriately in terms of data protection law and in accordance with fundamental human rights in the	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.5.78(3)	General Requirements	If personal data which have been transmitted or made available from another European Union Member State are to be transferred pursuant to subsection 1, the competent body of the other Member State must provide prior authorization of the transfer. Transfers without the prior authorization shall be permitted only if the transfer is necessary to prevent an immediate	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.5.78(4)	General Requirements	The controller transferring data pursuant to subsection 1 shall take appropriate measures to ensure that the recipient will transfer the data onward to other third countries or other international organizations only with the prior authorization of the controller. When deciding whether to authorize the transfer, the controller shall take into account all relevant	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.5.79	Data transfers with appropriate safeguards	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.5.79(1)	Data transfers with appropriate safeguards	In the absence of a decision pursuant to Article 36 (3) of Directive (EU) 2016/680, transfers which meet the remaining requirements of Section 78 shall be permitted also if	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
3.5.79(1)1	Data transfers with appropriate safeguards	appropriate safeguards with regard to the protection of personal data are provided for in a legally binding instrument; or	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	8	
3.5.79(1)2	Data transfers with appropriate safeguards	the controller has assessed all the circumstances surrounding the transfer and concludes that appropriate safeguards exist for the protection of personal data.	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
3.5.79(2)	Data transfers with appropriate safeguards	The controller shall document transfers pursuant to subsection 1 no. 2. The documentation shall include the date and time of the transfer, the identity of the recipient, the reason for the transfer and the personal data transferred. It shall be provided to the Federal Commissioner on request.	Functional	Intersects With	Documenting Data Processing Activities	PRI-14	Mechanisms exist to document Personal Data (PD) processing activities that covers collection, receiving, processing, storage, transmission, sharing, updating and/or disposal actions with sufficient detail to demonstrate conformity with applicable statutory, regulatory and contractual requirements.	5	
3.5.79(2)	Data transfers with appropriate safeguards	The controller shall document transfers pursuant to subsection 1 no. 2. The documentation shall include the date and time of the transfer, the identity of the recipient, the reason for the transfer and the personal data transferred. It shall be provided to the Federal Commissioner on request.	Functional	Intersects With	Accounting of Disclosures	PRI-14.1	Mechanisms exist to provide data subjects with an accounting of disclosures of their Personal Data (PD) controlled by: (1) The organization; and/or	5	
3.5.79(3)	Data transfers with appropriate safeguards	The controller shall file a report to the Federal Commissioner at least once a year covering transfers conducted on the basis of an assessment pursuant to subsection 1 no. 2. In this report, the controller may categorize	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
3.5.80	Data transfers without appropriate safeguards	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.5.80(1)	Data transfers without appropriate safeguards	If in derogation from Section 78 (1) no. 2, no decision pursuant to Article 36 (3) of Directive (EU) 2016/680 or appropriate safeguards as referred to in to protect the vital interests of a natural person;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD)	5	
3.5.80(1)1	Data transfers without appropriate safeguards		Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.5.80(1)2	Data transfers without appropriate safeguards	to safeguard legitimate interests of the data subject;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.5.80(1)3	Data transfers without appropriate safeguards	to prevent an immediate and serious threat to the public security of a country;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.5.80(1)4	Data transfers without appropriate safeguards	in individual cases for the purposes referred to in Section 45; or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.5.80(1)5	Data transfers without appropriate safeguards	in an individual case for the establishment, exercise or defence of legal claims relating to the purposes referred to in Section 45.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.5.80(2)	Data transfers without appropriate safeguards	The controller shall not transfer data pursuant to subsection 1 if the fundamental rights of the data subject override the public interest in the transfer.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.5.80(3)	Data transfers without appropriate safeguards	Section 79 (2) shall apply accordingly to transfers pursuant to subsection 1.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD)	5	
3.5.81	Other data transfers to recipients in third countries	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.5.81(1)	Other data transfers to recipients in third countries	In special individual cases and if all other requirements for data transfers to third countries are met, controllers may transfer personal data directly to recipients in third countries not referred to in Section 78 (1) no. 1 if the transfer is strictly necessary for the performance of their tasks and	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
3.5.81(1)1	Other data transfers to recipients in third countries	in the specific case no fundamental rights of the data subject override the public interest in the transfer;	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
3.5.81(1)2	Other data transfers to recipients in third countries	transfer to the bodies referred to in Section 78 (1) no. 1 would be ineffective or inappropriate, in particular because the transfer cannot be carried out in time; and	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
3.5.81(1)3	Other data transfers to recipients in third countries	the controller informs the recipient of the purposes of processing and instructs the recipient that the transferred data may be processed only to the extent necessary for these purposes.	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.5.81(2)	Other data transfers to recipients in third countries	In the case of subsection 1, the controller shall inform the bodies referred to in Section 78 (1) no. 1 of the transfer without delay, unless this is ineffective or inappropriate.	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
3.5.81(3)	Other data transfers to recipients in third	Section 79 (2) and (3) shall apply accordingly to transfers pursuant to subsection 1.	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the	5	
3.5.81(4)	Other data transfers to recipients in third countries	In the case of transfers pursuant to subsection 1, the transmitting controller shall obligate the recipient to process the transferred personal data without the controller's consent only for the purpose for which they were transferred.	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	5	
3.5.81(5)	Other data transfers to recipients in third countries	Agreements in the field of judicial cooperation in criminal matters and police cooperation shall remain unaffected.	Functional	No Relationship	N/A	N/A	N/A	0	
3.6	Cooperation among supervisory authorities	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.6.82	Mutual assistance	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3.7	Liability and penalties	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.7.83	Compensation	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.7.83(1)	Compensation	If a controller has caused a data subject to suffer damage by processing personal data in violation of this Act or other law applicable to this processing, the controller or its legal entity shall be obligated to provide compensation to the data subject. This obligation to provide	Functional	No Relationship	N/A	N/A	N/A	0	
3.7.83(2)	Compensation	The data subject may request appropriate financial compensation for non-material damage.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.7.83(3)	Compensation	If, in the case of automated processing of personal data, it is not possible to determine which of several controllers caused the damage, each controller or its legal entity shall be liable.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary	5	
3.7.83(4)	Compensation	Section 254 of the Civil Code shall apply to contributory negligence on the part of the data subject.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
3.7.83(5)	Compensation	The limitation provisions stipulated for tortious acts in the Civil Code shall apply accordingly with regard to statutory limitation.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary	5	
3.7.84	Penal provisions	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
4	Special provisions for processing in the context of activities outside the	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.85	Processing of personal data in the context of activities outside the	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.85(1)	Processing of personal data in the context of activities outside the	The transfer of personal data to a third country, to supranational or intergovernmental bodies or to international organizations in the context of activities outside the scope of Regulation (EU) 2016/679 and Directive (EU)	Functional	No Relationship	N/A	N/A	N/A	0	
4.85(2)	Processing of personal data in the context of activities outside the scope of Regulation (EU)	Section 16 (4) shall not apply to processing in the context of activities outside the scope of Regulation (EU) 2016/679 and Directive (EU) 2016/680 by workplaces within the remit of the Federal Ministry of Defence if the Federal Ministry of Defence determines in the individual case that meeting	Functional	No Relationship	N/A	N/A	N/A	0	
4.85(3)	Processing of personal data in the context of activities outside the scope of Regulation (EU)	Processing by public bodies of the Federation in the context of activities outside the scope of Regulation (EU) 2016/679 and Directive (EU) 2016/680 shall not be subject to the obligation to provide information in accordance with Article 13 (1) and (2) of Regulation (EU) 2016/679	Functional	No Relationship	N/A	N/A	N/A	0	
4.85(3)1	Processing of personal data in the context of activities outside the	in the cases referred to in Section 32 (1) nos. 1 to 3, or	Functional	No Relationship	N/A	N/A	N/A	0	
4.85(3)2	Processing of personal data in the context of	if meeting this obligation would disclose information which by law or by its nature must be kept secret, in particular because of legitimate interests of	Functional	No Relationship	N/A	N/A	N/A	0	
4.86	Processing of personal data for purposes of	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.86(1)	Processing of personal data for purposes of	To prepare and conduct government procedures for awards and honours, both the responsible bodies and other public and private bodies may	Functional	No Relationship	N/A	N/A	N/A	0	
4.86(2)	Processing of personal data for purposes of	If processing is conducted solely for the purposes listed in subsection 1, first sentence, Articles 13 to 16, 19 and 21 of Regulation (EU) 2016/679	Functional	No Relationship	N/A	N/A	N/A	0	
4.86(3)	Processing of personal data for purposes of government awards and honours	When processing special categories of personal data as referred to in Article 9 (1) of Regulation (EU) 2016/679, the controller shall take appropriate and specific measures to safeguard the rights of the data subject in accordance with Section 22 (2).	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
-------	----------	--	-------------------	----------------------	-------------	-------	---	-----------------------------	-------